TP 1 — Analyse Statique avec Binwalk

1. Téléchargement du firmware

Nom du fichier : XC.v8.7.22.48486.260227.1957.bin

Version : V8.7.22

Constructeur : Ubiquiti

2. Analyse du firmware avec Binwalk

Commande : binwalk XC.v8.7.22.48486.260227.1957.bin

Résultats principaux :

```
romain@PC-Pro-Romain:~/IoT/Formation-Jour2/TP1$ binwalk XC.v8.7.22.48486.260227.1957.bin

DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             Ubiquiti firmware header, header size: 264 bytes, ~CRC32: 0x2ECF66A2, version: "XC.qca955x.v8.7.22.48486.260227.1957"
268           0x10C           Ubiquiti partition header, header size: 56 bytes, name: "PARTu-boot", base address: 0x9F000000, data size: 237188 bytes
145028        0x23684         Certificate in DER format (x509 v3), header length: 4, sequence length: 64
153892        0x25924         U-Boot version string, "U-Boot 1.1.4-g4f57088a-dirty (Jan 26 2024 - 11:30:52)"
154276        0x25AA4         CRC32 polynomial table, big endian
230332        0x383BC         CRC32 polynomial table, big endian
231849        0x389A9         DER SHA1 hash
237520        0x39FD0         Ubiquiti partition header, header size: 56 bytes, name: "PARTkernel", base address: 0x9F050000, data size: 1008508 bytes
237576        0x3A008         uImage header, header size: 64 bytes, header CRC: 0xDF3F50EC, created: 2026-02-27 20:04:43, image size: 1008444 bytes, Data Address:
0x80002000, Entry Point: 0x80002000, data CRC: 0x9848DAB0, OS: Linux, CPU: MIPS, image type: OS Kernel Image, compression type: lzma, image name: "MIPS Ubiquiti Li
nux-2.6.32.68"
237640        0x3A048         LZMA compressed data, properties: 0x5D, dictionary size: 8388608 bytes, uncompressed size: 2872368 bytes
1246092       0x13038C        Ubiquiti partition header, header size: 56 bytes, name: "PARTrootfs", base address: 0x9F150000, data size: 9043968 bytes
1246148       0x1303C4        Squashfs filesystem, little endian, version 4.0, compression:lzma, size: 8791875 bytes, 1018 inodes, blocksize: 262144 bytes, created
: 2026-02-27 20:04:46
10290124      0x9D03CC        Ubiquiti firmware additional data, name: script, size: 398 bytes, size2: 398 bytes, CRC32: 19265c0f
10290180      0x9D0404        gzip compressed data, from Unix, last modified: 2026-02-27 20:02:12
10290586      0x9D059A        Signed Ubiquiti end header, RSA 2048 bit, header size: 264 bytes
```

Types détectés :

- Ubiquiti firmware
- Signature RSA
- Kernel Linux
- U-Boot Bootloader

Offsets importants :

- 0x0 -> Firmware Ubiquiti
- 0x25294 -> Version U-Boot
- 0x3A0A8 -> Kernel Linux
- 0x9D059A -> Signature RSA

Système de fichiers : SquashFS V4.0

Observations :

- Le firmware appartient à un équipement Ubiquiti
- Présence d'un bootloader U-Boot, typique des systèmes embarqués
- Le firmware contient un kernel Linux
- Présence d'un certificat et d'une signature RSA 2048 bits, ce qui indique que le firmware est signé

3. Extraction du firmware

Commande : binwalk -Me XC.v8.7.22.48486.260227.1957.bin

Résultat :

```
romain@PC-Pro-Romain:~/IoT/Formation-Jour2/TP1$ binwalk -Me XC.v8.7.22.48486.260227.1957.bin

Scan Time:     2026-04-01 10:50:38
Target File:   /home/romain/IoT/Formation-Jour2/TP1/XC.v8.7.22.48486.260227.1957.bin
MD5 Checksum:  432c0760ea626dea575966ab34a8987f
Signatures:    436

DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
237640        0x3A048         LZMA compressed data, properties: 0x5D, dictionary size: 8388608 bytes, uncompressed size: 2872368 bytes

WARNING: Extractor.execute failed to run external extractor 'sasquatch -p 1 -le -d 'squashfs-root-0' '%e'': [Errno 2] No such file or directory: 'sasquatch', 'sasq
uatch -p 1 -le -d 'squashfs-root-0' '%e'' might not be installed correctly

WARNING: Extractor.execute failed to run external extractor 'sasquatch -p 1 -be -d 'squashfs-root-0' '%e'': [Errno 2] No such file or directory: 'sasquatch', 'sasq
uatch -p 1 -be -d 'squashfs-root-0' '%e'' might not be installed correctly

WARNING: Symlink points outside of the extraction directory: /home/romain/IoT/Formation-Jour2/TP1/_XC.v8.7.22.48486.260227.1957.bin.extracted/squashfs-root/bin/sca
nparser -> /usr/www/glogo.cgi; changing link target to /dev/null for security purposes.

WARNING: Symlink points outside of the extraction directory: /home/romain/IoT/Formation-Jour2/TP1/_XC.v8.7.22.48486.260227.1957.bin.extracted/squashfs-root/bin/web
ping -> /usr/www/glogo.cgi; changing link target to /dev/null for security purposes.
```

Dossier généré : _XC.v8.7.22.48486.260227.1957.bin.extracted/

Observations :

- Message d'erreur : sasquatch: No such file or directory -> Binwalk tente d'utiliser sasquatch pour extraire SquashFS modifié

4. Exploration du système de fichiers

Commandes utilisées :

1ère commande : cd _XC.v8.7.22.48486.260227.1957.bin.extracted

2ème commande : ls

```
romain@PC-Pro-Romain:~/IoT/Formation-Jour2/TP1/_XC.v8.7.22.48486.260227.1957.bin.extracted$ ls
1303C4.squashfs  3A048.7z  _9D0404.extracted  squashfs-root-0
3A048            9D0404    squashfs-root
```

3ème commande : find . -type f -exec file {} \; | grep ELF

```
romain@PC-Pro-Romain:~/IoT/Formation-Jour2/TP1/_XC.v8.7.22.48486.260227.1957.bin.extracted$ find . -type f -exec file {} \; | grep ELF
./squashfs-root/bin/dhcp-fwd: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section header
./squashfs-root/bin/dnsmasq: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section header
./squashfs-root/bin/xtables-multi: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section h
eader
./squashfs-root/bin/athbox: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section header
./squashfs-root/bin/dhcp6c: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section header
./squashfs-root/bin/i2cget: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section header
./squashfs-root/bin/format_byte_dump: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no sectio
n header
./squashfs-root/bin/ubntbox: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section header
./squashfs-root/bin/wpad: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section header
./squashfs-root/bin/i2cdump: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section header
./squashfs-root/bin/memtester: ELF 32-bit MSB executable, MIPS, MIPS32 rel2 version 1 (SYSV), dynamically linked, interpreter /lib/ld-uClibc.so.0, no section heade
r
```

5. Analyse des fichiers critiques

A. Fichiers sensibles

/etc/passwd :

```
romain@PC-Pro-Romain:~/IoT/Formation-Jour2/TP1/_XC.v8.7.22.48486.260227.1957.bin.extracted/
squashfs-root/etc$ cat passwd
ubnt:VvpvCwhccFv6Q:0:0:Administrator:/:/bin/sh
```

Observations :

- UID = 0 → privilèges root
- Shell actif : /bin/sh
- Le compte ubnt possède des droits administrateurs complets
- Le mot de passe est stocké sous forme de hash

B. Scripts d'initialisation

Dossier : /etc/init.d/

```
romain@PC-Pro-Romain:~/IoT/Formation-Jour2/TP1/_XC.v8.7.22.48486.260227.1957.bin.extracted/squashfs-root/etc/init.d$ ls
plugin
romain@PC-Pro-Romain:~/IoT/Formation-Jour2/TP1/_XC.v8.7.22.48486.260227.1957.bin.extracted/squashfs-root/etc/init.d$ cat plugin
#!/bin/sh

. /usr/etc/rc.d/rc.funcs

if [ -z $PLUGIN_NORUN ]; then
        case "$1" in
                start|stop)
                run_plugin $2 $1
                ;;
                *)
                echo "Usage: /usr/etc/init.d/plugin (start|stop) plugin_name"
                ;;
        esac
fi
```

C. Interface Web

Dossier : /www/

```
romain@PC-Pro-Romain:~/IoT/Formation-Jour2/TP1/_XC.v8.7.22.48486.260227.1957.bin.extracted/squashfs-root/usr/www$ ls
1.chunk.396fc7b6.css.gz  4.chunk.fe7e7e39.css.gz  favicon.ico  help          index.html          main.598abe80.js.gz  translations
1.chunk.396fc7b6.js.gz   4.chunk.fe7e7e39.js.gz   fonts        hist-stats.cgi  js                  signal.cgi           vendors.chunk.33d4dad1.css.gz
3.chunk.824e9896.js.gz   check.html               glogo.cgi    images          main.598abe80.css.gz  status.cgi           vendors.chunk.33d4dad1.js.gz
```

Fichiers identifiés :

- index.html
- check.html

Fichiers JavaScript :

- main.*.js
- vendors.*.js
- chunk.*.js

Fichiers CSS :

- main.*.css

Scripts CGI :

- login.cgi
- help.cgi
- signal.cgi
- status.cgi

Dossiers :

- fonts/
- images/
- translations/

Observations :

- Le firmware contient une interface web complète
- Utilisation de fichiers JavaScript (.js.gz) → difficile à analyser directement (obfuscation légère)
- Présence de scripts CGI :
    - Indiquent une interaction serveur (backend)potentiellement vulnérables si mal sécurisés
- L'interface semble moderne (usage de chunks JS → framework)
- Présence de fichiers compressés (.gz) → optimisation pour le web

Analyse de sécurité

Informations sensibles trouvées :

- Présence d'un système de fichiers complet contenant des fichiers critiques (/etc, /bin, /www)
- Interface web embarquée avec scripts CGI (login.cgi, status.cgi, etc.)

Comptes par défaut : ubnt (compte administrateur avec privilèges root)

Failles potentielles :

- Compte administrateur (ubnt) avec UID 0 exploitable en cas de mot de passe faible
- Présence d'un shell système (/bin/sh) permettant une exécution de commandes